

REPORT OF JWT TOKEN VULNERABILITY

Date : 24/01/2026

INTRODUCTION (By Lavish)

JWT(JSON web token), it is a widely used authentication and authorisation mechanism in modern web applications and API based systems. Due to its extensive adoption, any security weakness related to JWT can pose a serious risk to applications and organisations.

In this discussion we have analysed a high severity JWT related security vulnerability from a practical and real world perspective. The objective of this analysis is to understand the role of CVE and CVSS in identifying and assessing vulnerabilities, examine why its issue is considered critical and explore how it can be realistically exploited by attackers.

WHAT IS CVE AND CVSS (By Kishan)

- CVE stands for the common vulnerability exposures, it is global system used to identify publicly known security vulnerabilities
- Each vulnerability is assigned a unique CVE ID to ensure clear and consistent reference.
- CVE helps security teams, vendors, and researchers communicate about vulnerabilities without confusions
- CVSS is known as Common Vulnerability scoring system, it is used to assess the severity of vulnerabilities identified by CVE
- It provides a numerical score ranging from 0 to 10 to represent the risk level.
- A higher CVSS score indicates greater potential security impact.
- CVSS helps organisations prioritise vulnerabilities that require immediate attention.

OVERVIEW OF JWT AND ITS IMPORTANCE (By Kishan)

- JWT is a widely used method for handling authentication and authorisation
- It allows stateless sessions managements in modern applications
- JWT is commonly used in web applications, APIs, and modern mobile platforms
- Secure JWT implementations is critical because weak validation can expose systems to serious attacks

WHY THIS VULNERABILITY IS IMPORTANT (By Kishan)

- This vulnerability has a CVSS score greater than or equal to 7, that indicating high risk
- Its is exploitable in real production environments
- It often affects widely deployed applications and services
- Successful exploitation can allow unauthorised access and privilege escalation
- Ignoring such vulnerabilities can results in data breaches and operational failures

HOW THE VULNERABILITY CAN BE REALISTICALLY EXPLOITED (By Lavish)

- Attackers obtain a JWT token from application traffic or storage
- If the server does not strictly validate the token signature or algorithm, manipulation becomes possible.
- Token payload fields such as user roles can be altered by the attacker
- The modified token is sent back to the server and accepted as valid
- This attack is remote and does not require user interaction

WHAT AN ATTACKER CAN DO AFTER EXPLOITATION (By Lavish)

- Gain unauthorised access to user and admin accounts
- Bypass authentication and misuse of protected features
- Steal, modify and delete sensitive data

IMPACT IN REAL PRODUCTION ENVIRONMENT (By Kishan)

- Exposure of sensitive data and internal systems
- Service disruptions and loss of customers loss
- Financial, legal and compliance related consequences

REMEDIATIONS AND PREVENTIVE METHODS (By Lavish)

- Strictly validate JWT signatures and algorithms
- Verify the tokens claims and use short lived tokens
- Keep JWT libraries updated and test authentication logic

EXPLAINING THE IMPACT TO MANAGEMENT (By Kishan)

- Comparable to leaving the critical office door unlocked
- Leads to the data loss, downtime and reputational damage
- Preventive fixes are cheaper than post incident recovery

CONCLUSION (By Kishan)

CVE helps identify security vulnerabilities, while CVSS determines their severity. High risk JWT vulnerabilities can be realistically exploited and cause serious damage to the business and organisations. Timely remediation and clear communication with management are essential to maintain security and continuity.

Report created and submitted by Kishan and Lavish